SEGURIDAD DE LA INFORMACIÓN
para Negocios Digitales

SUPERCUADERNILLO

Resumen integrador

Módulos 1 a 13

Fundamentos y criptografía · Gestión de riesgos y nube · Protección de datos, cibercrimen y ética · Gobierno, factor humano, incidentes y continuidad

Autor: Mg. Ing. Rodrigo Atilio Elgueta

Este material resume los contenidos de los 13 módulos y sirve como base de estudio para la evaluación integradora (Verdadero/Falso, Unir conceptos y Opción múltiple).

Índice

Cómo usar este cuadernillo **3**

Parte I — Fundamentos de la seguridad 4

1. La huella digital: una demo para empezar **4**

2. Fundamentos: los 5 conceptos y los pilares CID **4**

2.1. Los 5 conceptos fundamentales 5

2.2. Los tres pilares CID 5

3. Amenazas para negocios digitales y herramientas **6**

3.1. Panorama de amenazas 6

3.2. Herramientas gratuitas de verificación 7

4. Criptografía y confianza digital **7**

4.1. Simétrico vs asimétrico 7

4.2. Hashing 8

4.3. HTTPS, certificados y firma digital 8

Parte II — Gestión de riesgos 10

5. Gestión de riesgos y matriz de probabilidad e impacto **10**

5.1. El ciclo de gestión de riesgos 10

5.2. Mapa de calor (matriz P×I) 10

5.3. Opciones de tratamiento: las 4 T 11

6. BIA, controles e ISO/IEC 27001/27002 **11**

6.1. BIA: Análisis de Impacto al Negocio 11

6.2. Tipos de controles 12

6.3. ISO/IEC 27001 y 27002 12

7. Seguridad en la nube **13**

7.1. Errores de configuración más frecuentes 13

7.2. Backups en la nube: regla 3-2-1 14

Parte III — Marco normativo y ético 15

8. Protección de datos personales **15**

8.1. Ley 25.326 de Protección de Datos Personales (Argentina, 2000) 15

8.2. GDPR (Unión Europea, 2018) . . . 15
8.3. Derechos ARCO . . . 16

9. Cibercrimen, privacidad por diseño y cookies 16
9.1. Ley 26.388 de delitos informáticos (Argentina, 2008) . . . 16
9.2. Privacidad por Diseño (Privacy by Design) . . . 17
9.3. Cookies . . . 17

Parte IV — Gobierno, factor humano, incidentes y continuidad 19

10. Hacking ético, OSINT y simulacros de phishing 19
10.1. Fases del pentesting . . . 19
10.2. Señales de alerta de un correo de phishing . . . 19
10.3. Simulacro de phishing . . . 20

11. Gobierno de la seguridad y Política de Seguridad Aceptable 20
11.1. La pirámide documental . . . 20
11.2. Política de Seguridad Aceptable (PSA / AUP) . . . 21
11.3. Roles . . . 21

12. Factor humano y gestión de incidentes 21
12.1. Fases de la gestión de incidentes . . . 22
12.2. La Junta de Crisis: 4 roles . . . 22

13. Continuidad del negocio y auditoría 23
13.1. Componentes de un plan de continuidad . . . 23
13.2. Auditoría de seguridad . . . 23
13.3. Ciclo PHVA / PDCA de mejora continua . . . 23
13.4. Plan de Respuesta a Incidentes: checklist de referencia . . . 24

Glosario integrador 25

Cómo usar este cuadernillo

Cada módulo resume las definiciones, tablas, casos y reglas prácticas que hay que dominar. Al final de cada uno hay un recuadro verde de **Ideas para recordar**. Al cierre se incluye un **glosario integrador**.

Parte	Contenido	Módulos
I	Fundamentos: CID, conceptos de riesgo, amenazas, herramientas y criptografía	1 a 4
II	Gestión de riesgos: matriz P×I, BIA, controles, ISO 27001/27002 y nube	5 a 7
III	Marco normativo y ético: datos personales, cibercrimen, privacidad por diseño y cookies	8 y 9
IV	Gobierno, factor humano, incidentes, continuidad y auditoría	10 a 13

La idea que atraviesa todo el curso

La seguridad de la información no es un gasto ni un tema exclusivo del área de sistemas: es un **habilitador de confianza** y una ventaja competitiva para cualquier negocio digital.

PARTE I
Fundamentos de la seguridad

Módulo 1 — La huella digital: una demo para empezar

El curso arranca con una experiencia: los participantes ingresan desde su celular a una página web aparentemente inofensiva. Sin que lo adviertan con claridad, la página **solicita acceso a la cámara** del dispositivo y transmite la imagen a un panel controlado por el docente.

Lección de la demo

No hubo un "hackeo" sofisticado: hubo un diseño que aprovechó que el usuario no leyó, no notó o aceptó un permiso sin pensar. En un negocio digital real, eso es una **brecha de seguridad**. La demo es, en esencia, una demostración controlada de **hacking ético** (Módulo 10): técnicas de ataque usadas con autorización y con propósito educativo.

Concepto	En la demo
Activo	La imagen personal, la cámara, la privacidad.
Amenaza	El sitio diseñado para acceder a la cámara sin evidencia clara.
Vulnerabilidad	Aceptar permisos sin leer; no verificar la URL; confiar ciegamente en un enlace.
Impacto	La foto termina en un panel que el usuario no controla (en escala real: chantaje, suplantación, exposición).
Pilar CID violado	**Confidencialidad**: se accedió a la imagen sin autorización consciente.

Definición

Huella digital: rastro de datos que dejamos al usar tecnología. **Permiso (app/navegador):** autorización para acceder a un recurso del dispositivo (cámara, micrófono, ubicación, contactos).

✓ Ideas para recordar

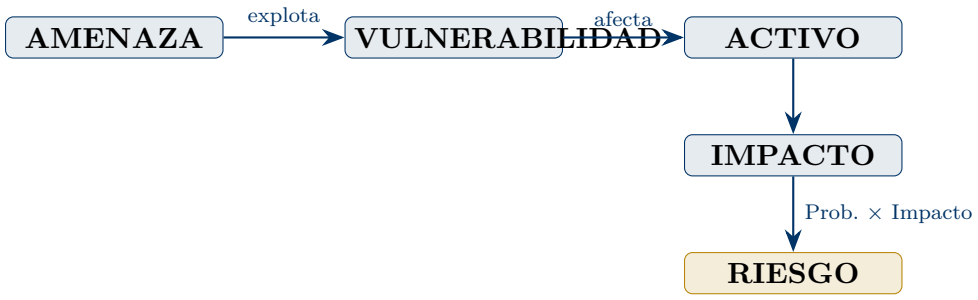
- La vulnerabilidad más común es humana: aceptar sin leer.
- Una página "inocente" puede acceder a recursos sensibles si se le otorga el permiso.

Módulo 2 — Fundamentos: los 5 conceptos y los pilares CID

2.1 Los 5 conceptos fundamentales

Concepto	Definición	Ejemplo (e-commerce chico)
Activo de información	Cualquier elemento con valor para la organización que debe protegerse: datos, software, hardware, conocimiento, reputación, personas.	Base de datos de 5.000 clientes con datos de tarjeta.
Amenaza	Evento o actor *potencial* que puede causar daño. No es el daño en sí.	Ataque de phishing a un empleado de atención al cliente.
Vulnerabilidad	Debilidad de un activo, proceso o control que una amenaza puede explotar. Está "de nuestro lado".	Empleado sin capacitación que reutiliza su contraseña en sitios personales.
Impacto	Consecuencia (económica, legal, reputacional, operativa) cuando la amenaza explota la vulnerabilidad.	Multa, pérdida de clientes, nota en medios.
Riesgo	Combinación de la **probabilidad** y el **impacto**.	Alto: probabilidad media-alta e impacto severo.

$$\text{RIESGO} \approx \text{PROBABILIDAD} \times \text{IMPACTO}$$



2.2 Los tres pilares CID

Pilar	Significado	Se viola cuando...
Confidencialidad	Solo accede quien está **autorizado**.	Se reenvía la nómina a todo el equipo; un bucket queda público; se intercepta HTTP sin cifrar.
Integridad	La información es **exacta y completa** y no fue alterada sin autorización.	Un malware modifica las cuentas bancarias destino en una fintech.
Disponibilidad	La información está accesible **cuando se la necesita**.	Un ataque DDoS deja caída una app de delivery en la hora del almuerzo; un backup se corrompe.

Atención con la confusión más frecuente

"Accesible solo para quien está autorizado" es **confidencialidad**, no disponibilidad. Disponibilidad es que esté accesible *cuando se necesita*. Si cualquier pilar se rompe, hay un **incidente**.

✓ Ideas para recordar

- Amenaza = posibilidad de daño; vulnerabilidad = debilidad propia que la amenaza explota.
- Riesgo ≈ Probabilidad × Impacto.
- CID = Confidencialidad, Integridad, Disponibilidad.

Módulo 3 — Amenazas para negocios digitales y herramientas

3.1 Panorama de amenazas

Amenaza	Descripción	Pilar más afectado
Phishing	Suplantación de identidad (correo, SMS, web falsa) para robar credenciales o datos.	Confidencialidad
Spear Phishing	Phishing **dirigido e hiper-personalizado** a una víctima concreta.	Confidencialidad
Ransomware	Malware que **cifra los archivos** y exige un rescate (en general en criptomonedas). Hoy suele sumar amenaza de publicar los datos.	Disponibilidad (y C/I si hay fuga)
Ingeniería social	Manipulación psicológica de las personas; ataca al eslabón más débil: el humano. Ej.: llamar como "soporte técnico" y pedir el código 2FA.	Confidencialidad
Fraude / BEC	Suplantar a un directivo, proveedor o cliente para inducir una transferencia. En el **BEC** se compromete o suplanta el correo corporativo de un ejecutivo.	Confidencialidad e Integridad
Credential Stuffing	Ataque automatizado que prueba contraseñas filtradas en otros sitios.	Confidencialidad

Caso "FintechYa"

Una fintech de 20 empleados sufre un **spear phishing**: el gerente de RR.HH. recibe "Recibos_Sueldo_Actualizados.pdf.exe". Windows ocultaba la extensión real ".exe" y el gerente hizo doble clic. Se instaló un **ransomware** que cifró la base de clientes: **5 días sin procesar transacciones**.

Consecuencias: económica (u$s 50.000 de ingresos no percibidos), reputacional (tendencia negativa en redes) y legal (denuncia ante la autoridad de datos personales). **Pilar afectado**

principalmente: disponibilidad.

3.2 Herramientas gratuitas de verificación

Herramienta	Para qué sirve
Have I Been Pwned	Base de datos (creada por Troy Hunt) de cuentas comprometidas en brechas públicas: permite saber si un correo o teléfono fue filtrado.
VirusTotal	Servicio de Google que analiza archivos y URLs sospechosas con más de 70 motores antivirus y sandboxing.
Gestores de contraseñas	Bitwarden, 1Password, KeePass: generan, guardan y autocompletan contraseñas robustas en una bóveda cifrada; solo hay que recordar una.

Regla de oro

Nunca reutilizar la contraseña del correo en servicios de terceros: si el tercero es hackeado, los atacantes la probarán en todos lados (*credential stuffing*). Activar **2FA/MFA** (algo que sé + algo que tengo).

✓ Ideas para recordar

- Phishing, ransomware, ingeniería social y fraude/BEC son las amenazas más comunes.
- **Sandbox**: entorno aislado para ejecutar archivos sospechosos sin riesgo.
- **Breach (brecha)**: incidente donde se expone información confidencial.

Módulo 4 — Criptografía y confianza digital

Definición

Cifrar es transformar texto plano en texto cifrado usando una **clave**, de modo que solo quien tiene la clave adecuada pueda revertirlo.

4.1 Simétrico vs asimétrico

	Simétrico (“caja fuerte con una llave”)	Asimétrico (“buzón público”)
Claves	Una sola, compartida	Par: pública (se comparte) + privada (secreta)
Velocidad	Muy rápido	Más lento
Uso típico	Datos en reposo, sesiones HTTPS	Establecer la conexión, firma digital
Desafío	Distribuir la clave de forma segura	Saber que la clave pública es de quien dice ser (certificados)
Ejemplo	AES-256	RSA, ECC

Se usan juntos

HTTPS es un sistema **híbrido**: usa cifrado asimétrico para presentarse y negociar una **clave de sesión simétrica**, y luego cifrado simétrico para transmitir los datos rápido.

4.2 Hashing

Una **función hash** toma cualquier dato y produce una cadena de **longitud fija**. Es **irreversible** y **no usa clave**. Un mínimo cambio ("Hola" vs "hola") produce un hash totalmente distinto, por eso sirve para detectar alteraciones.

	Cifrado	Hash
¿Reversible?	Sí, con la clave correcta	No
Propósito	Proteger datos que necesito leer después	Verificar integridad; almacenar contraseñas
Salida	Longitud variable	Longitud fija (SHA-256: 256 bits, 64 caracteres hex)

Almacenamiento de contraseñas

Nunca en texto plano. Nunca con hashes simples y rápidos como MD5. Se guardan **hasheadas con funciones lentas (bcrypt, Argon2) y un *salt* único por usuario**. El salt evita ataques de diccionario y *rainbow tables* (tablas precomputadas de hashes). Aun hasheada, una contraseña débil como "123456" sigue siendo vulnerable porque es lo primero que se prueba.

4.3 HTTPS, certificados y firma digital

HTTPS paso a paso: (1) el navegador pregunta "¿quién sos?"; (2) el servidor presenta su **certificado digital**, emitido por una Autoridad Certificante; (3) el navegador lo valida; (4) se negocia una clave de sesión simétrica con criptografía asimétrica; (5) todo viaja cifrado. Sin HTTPS el navegador muestra "No seguro".

Firma digital

Garantiza **autenticidad** (quién firmó) e **integridad** (que no se modificó). Funcionamiento:

1. Se calcula el **hash** del documento.
2. Se cifra ese hash con la **clave privada** del firmante: esa es la firma.
3. El receptor descifra la firma con la **clave pública** del firmante y compara con el hash que calcula del documento recibido.
4. Si coinciden, el documento es auténtico e íntegro.

Escenario	Criptografía aplicada	Pilar
Pago con tarjeta	HTTPS/TLS + tokenización en la pasarela	Confidencialidad
Contraseñas de usuarios	bcrypt/Argon2 + salt	Confidencialidad
Factura o contrato digital	Firma digital	Integridad + autenticidad
Backup de la base	Cifrado simétrico AES-256	Confidencialidad
Descarga de un instalador	Hash SHA-256 para verificar que no fue adulterado	Integridad
Mensajería (WhatsApp, Signal)	Cifrado de extremo a extremo (E2EE)	Confidencialidad

Uso crítico de la IA

Reglas para usar IA generativa en todo el curso: **transparencia** (declarar herramienta, uso y prompt), **verificación obligatoria** (ninguna salida se entrega "tal cual": se contrasta con fuentes confiables y se marca lo correcto, lo impreciso y lo sobre-simplificado) y **responsabilidad** (el autor responde por el resultado final, use o no IA).

✓ **Ideas para recordar**

- Cifrado = reversible con clave. Hash = irreversible, longitud fija.
- HTTPS combina asimétrico (negociación) y simétrico (datos).
- Firma digital = hash cifrado con la clave **privada**; se verifica con la **pública**.

PARTE II
Gestión de riesgos

Módulo 5 — Gestión de riesgos y matriz de probabilidad e impacto

El objetivo NO es el "riesgo cero"

Eliminar todos los riesgos es técnicamente imposible y económicamente inviable. El objetivo es **administrar el riesgo** hasta un nivel aceptable para el negocio.

5.1 El ciclo de gestión de riesgos

Proceso **continuo y cíclico** (no se hace una sola vez):

1. **Identificación:** ¿qué puede salir mal? (activos, amenazas, vulnerabilidades).
2. **Análisis:** ¿qué tan probable y qué tan grave? (P e I).
3. **Evaluación:** ¿cuáles son prioritarios? (matriz P×I).
4. **Tratamiento:** ¿qué hacemos? (las 4 T).

5.2 Mapa de calor (matriz P×I)

Probabilidad ↓ / Impacto →	Bajo	Medio	Alto
Alta	MEDIO	ALTO	CRÍTICO
Media	BAJO	MEDIO	ALTO
Baja	BAJO	BAJO	MEDIO

- **Crítico / Alto:** tratamiento inmediato.
- **Medio:** plan de acción a mediano plazo y monitoreo.
- **Bajo:** se acepta o se monitorea periódicamente.

5.3 Opciones de tratamiento: las 4 T

Estrategia	Descripción	Ejemplo
Mitigar (reducir)	Aplicar controles para bajar la probabilidad o el impacto.	Implementar MFA contra el robo de credenciales.
Transferir (compartir)	Pasar el impacto financiero a un tercero.	Seguro de ciber-riesgo; hosting tercerizado con SLA.
Aceptar (tolerar)	Asumir el riesgo porque el control cuesta más que el daño potencial.	Tolerar 10 min de caída al año porque la redundancia cuesta mucho más que la pérdida.
Evitar (eliminar)	Dejar de realizar la actividad que genera el riesgo.	No almacenar tarjetas propias y usar siempre una pasarela externa.

✓ Ideas para recordar

- Orden del ciclo: identificar → analizar → evaluar → tratar.
- Probabilidad Alta × Impacto Bajo = **Medio**; Alta × Alto = **Crítico**.
- Las 4 T son todas estrategias válidas: Mitigar, Transferir, Aceptar, Evitar.

Módulo 6 — BIA, controles e ISO/IEC 27001/27002

6.1 BIA: Análisis de Impacto al Negocio

Definición

El **BIA (Business Impact Analysis)** identifica los procesos críticos y cuantifica el impacto de su interrupción para **priorizar** la recuperación, **dimensionar inversiones** y **definir objetivos de recuperación**.

Sigla	¿Qué pregunta responde?	Ejemplo
MTD	¿Cuánto tiempo **máximo** puede estar caído el proceso antes de que el daño sea inaceptable?	"La pasarela no puede estar caída más de 2 h."
RTO	¿En cuánto tiempo nos **proponemos** recuperarlo?	"Volver a operar en 1 h."
RPO	¿Cuántos **datos** podemos perder? Define cada cuánto se hace backup.	"Backup cada 15 min."

Regla práctica

Siempre debe cumplirse **RTO** $\leq$ **MTD**. Si el proceso tolera 2 horas caído pero el plan tarda 6 horas en recuperarlo, hay un problema de diseño.

6.2 Tipos de controles

Un **control** es cualquier medida diseñada para reducir la probabilidad o el impacto de un riesgo.

Categoría	Abarca	Ejemplos
Técnicos	Soluciones tecnológicas	Firewall, MFA, cifrado, antivirus, backups, IDS/IPS
Humanos / organizativos	Personas y procesos	Capacitación, concientización, políticas, roles
Físicos	Espacio y hardware	Cámaras, control de acceso al data center, UPS
Legales / normativos	Leyes y contratos	Política de privacidad, NDA, seguros, cláusulas

Según su **función en el tiempo**:

- **Preventivo:** evita que el incidente ocurra (MFA, capacitación).
- **Detectivo:** alerta mientras ocurre (antivirus, cámaras, monitoreo de tráfico).
- **Correctivo:** restaura la normalidad después (backups, plan de respuesta).

Criterio costo-beneficio

Un control se implementa si **su costo es menor que el impacto esperado del riesgo**. Si proteger un activo cuesta más que el activo mismo, lo correcto suele ser **aceptar** o **transferir**.

6.3 ISO/IEC 27001 y 27002

	ISO/IEC 27001	ISO/IEC 27002
¿Qué es?	Norma de **requisitos** de un SGSI (Sistema de Gestión de Seguridad de la Información).	**Catálogo de buenas prácticas** y controles.
Rol	Dice **QUÉ** hay que hacer.	Sugiere **CÓMO** hacerlo.
¿Certificable?	**Sí**.	**No** por sí sola.
Analogía	La "constitución".	El "manual de procedimientos".

Importan por **confianza comercial**, **orden interno** y **ventaja competitiva** (muchos contratos B2B exigen cumplimiento de estándares).

✓ Ideas para recordar

- MTD = tolerancia máxima; RTO = objetivo de tiempo; RPO = pérdida máxima de datos.
- Preventivo / detectivo / correctivo.
- 27001 = requisitos, certificable. 27002 = catálogo de controles.

Módulo 7 — Seguridad en la nube

Modelo de responsabilidad compartida

El proveedor (AWS, Azure, GCP) se ocupa de la **seguridad DE la nube**: hardware, data centers, red física, hipervisor. El cliente se ocupa de la **seguridad EN la nube**: sus datos, sus identidades (IAM), la configuración de sus servicios y el cifrado de su información.

Capa	IaaS	PaaS	SaaS
Infraestructura, red, hipervisor	Proveedor	Proveedor	Proveedor
Sistema operativo y middleware	**Cliente**	Proveedor	Proveedor
Aplicación	**Cliente**	**Cliente**	Proveedor
Datos	**Cliente**	**Cliente**	**Cliente**
Identidades y accesos (IAM)	**Cliente**	**Cliente**	**Cliente**

IaaS (ej. AWS EC2): se alquilan máquinas virtuales. **PaaS** (ej. Azure App Service): se sube la aplicación. **SaaS** (ej. Gmail, Office 365, Slack): se usa un software ya hecho.

Lo que nunca cambia

En IaaS, PaaS o SaaS, **los datos y las identidades (IAM) siempre son responsabilidad del cliente**. El error más común es creer que "si está en AWS, ya está seguro".

7.1 Errores de configuración más frecuentes

1. Buckets / almacenamiento **público**: cualquiera puede descargar los datos.
2. IAM con **permisos excesivos**.
3. **Access keys** escritas en el código o en repositorios públicos.
4. Cuentas administradoras **sin MFA**.
5. **Sin backups** o sin probarlos.

IAM y menor privilegio

IAM (Identity and Access Management) controla **quién** puede hacer **qué** sobre **qué recurso**. El **principio de menor privilegio** indica que cada usuario o servicio tenga solo los permisos mínimos necesarios: si se compromete, el daño queda acotado.

Casos reales

Capital One (2019), 100 millones de registros: un atacante explotó una mala configuración del **WAF** (firewall de aplicación web) y luego un **rol IAM con permisos excesivos**. La falla fue de configuración y permisos, no de la infraestructura de AWS: se

incumplió el **menor privilegio**.

Buckets S3 públicos (patrón recurrente): el almacenamiento no es privado por defecto si no se configura; puede pasar meses expuesto sin monitoreo.

7.2 Backups en la nube: regla 3-2-1

El proveedor garantiza la durabilidad de la infraestructura, pero **el backup de los datos es responsabilidad del cliente**.

- **3** copias (la original + 2 backups),
- en **2** medios distintos,
- con **1** copia fuera del sitio principal (otra región o cuenta).

El **RPO** define cada cuánto se hace backup y el **RTO** qué tan rápido hay que restaurar. **Un backup que no se prueba no es un backup.**

✓ Ideas para recordar

- Seguridad DE la nube = proveedor; seguridad EN la nube = cliente.
- La mayoría de las brechas en la nube son errores de configuración evitables.
- Checklist mínima: almacenamiento privado, MFA en admins, menor privilegio, cifrado en reposo y tránsito, backups 3-2-1 probados, logging y monitoreo, parcheo.

PARTE III
Marco normativo y ético

Módulo 8 — Protección de datos personales

Los datos personales dejaron de verse como "propiedad" de la empresa: son una **extensión de la persona** y le son **confiados** a la organización.

Definición

Dato personal: información que identifica o hace identificable a una persona física.

8.1 Ley 25.326 de Protección de Datos Personales (Argentina, 2000)

- **Consentimiento informado:** libre, expreso e informado.
- **Finalidad:** los datos solo se usan para el propósito informado.
- **Calidad del dato:** ciertos, exactos y actualizados; si ya no son necesarios, se destruyen.
- **Deber de confidencialidad y seguridad** del responsable del archivo.

Autoridad de control: **AAIP** (Agencia de Acceso a la Información Pública).

8.2 GDPR (Unión Europea, 2018)

Efecto extraterritorial

El GDPR aplica a **cualquier empresa del mundo** que ofrezca bienes o servicios a personas en la UE o monitoree su comportamiento. Un e-commerce argentino que envía a España **debe cumplir el GDPR**.

Aspecto	Ley 25.326 (Argentina)	GDPR (UE)
Sanciones	Relativamente bajas	Hasta 20 millones de euros o el **4 % de la facturación global anual**
Consentimiento	Expreso e informado	**Explícito y afirmativo** (no vale el silencio ni la casilla pre-tildada)
Notificación de brechas	Sin plazo estricto en la ley original (sí en resoluciones de la AAIP)	A la autoridad en **72 horas** desde la detección
DPO	No siempre obligatorio	Obligatorio para ciertas empresas y volúmenes

8.3 Derechos ARCO

Derecho	Lo que puede exigir el usuario	Plazo (Arg.)
Acceso	"Quiero saber qué datos tienen de mí y para qué los usan."	10 días
Rectificación	"Tienen mal mi dirección; actualícenla."	10 días
Cancelación (supresión)	"Ya no quiero ser cliente; bórrenme." (derecho al olvido)	10 días
Oposición	"Pueden tenerme como cliente, pero no usen mis datos para marketing."	10 días

Cancelación vs retención legal

La cancelación no es absoluta: se borran los datos de marketing y perfil, pero los datos de facturación se **bloquean y retienen** el tiempo que exige la ley fiscal. Toda empresa necesita un **canal y un procedimiento interno** para recibir y ejecutar solicitudes ARCO.

Uso crítico de la IA

Pedirle a una IA que resuma una política de privacidad tiene un **riesgo de cumplimiento**: puede omitir cláusulas críticas (venta de datos a terceros, transferencias internacionales, retención) o "alucinar" derechos inexistentes. Siempre se audita contra el texto original antes de publicar.

✓ Ideas para recordar

- Ley 25.326 = datos personales en Argentina; autoridad: AAIP.
- GDPR: extraterritorial, multas de hasta el 4 % global, notificación en 72 h.
- ARCO = Acceso, Rectificación, Cancelación, Oposición (10 días en Argentina).

Módulo 9 — Cibercrimen, privacidad por diseño y cookies

9.1 Ley 26.388 de delitos informáticos (Argentina, 2008)

Modificó el Código Penal para incorporar los delitos informáticos.

Delito	Qué sanciona
Acceso indebido	Entrar sin autorización a un sistema o dato restringido.
Retención de datos	Apoderarse de datos o retenerlos contra la voluntad del dueño.
Daño informático	Alterar, destruir o inutilizar datos o sistemas (ej. borrar una base).
Fraude informático	Manipular datos para obtener un beneficio económico injusto (ej. alterar precios en un e-commerce).
Interceptación de comunicaciones	Captar comunicaciones electrónicas no destinadas al público (ej. *sniffing*).
Pornografía infantil	Producción, tenencia o distribución de material de abuso sexual infantil.
Grooming	Contacto digital de un adulto con un menor con fines sexuales.

Conocer la ley permite saber **cuándo un incidente debe denunciarse** como delito penal.

9.2 Privacidad por Diseño (Privacy by Design)

Enfoque propuesto por **Ann Cavoukian**: la privacidad se incorpora en la arquitectura del producto **desde el inicio**, no como un parche al final. Sus 7 principios:

1. Proactivo, no reactivo.
2. **Privacidad por defecto** (*default privacy*): si el usuario no hace nada, está protegido.
3. Privacidad embebida en el diseño.
4. Funcionalidad total (suma positiva): seguridad *y* usabilidad.
5. Seguridad de extremo a extremo durante todo el ciclo de vida del dato.
6. Visibilidad y transparencia.
7. Respeto por la privacidad del usuario.

Dark patterns

Diseños de interfaz **engañosos** que manipulan al usuario (suscripciones difíciles de cancelar, “Aceptar todo” gigante y “Rechazar” escondido). Aunque aumenten ventas a corto plazo, erosionan la confianza en la marca.

9.3 Cookies

HTTP es “sin estado”: las cookies son pequeños archivos de texto que permiten al servidor recordar al usuario.

Tipo	Característica	Uso
De sesión	Se borran al cerrar el navegador.	Carrito de compras.
Persistentes	Tienen fecha de expiración; quedan en el disco.	Idioma, "Recordarme".
De origen (first-party)	Creadas por el dominio que se está visitando.	Autenticación, preferencias.
De terceros (third-party)	Creadas por **dominios distintos** (anunciantes, trackers).	Publicidad comportamental, analítica cruzada.

Las cookies **no esenciales** requieren consentimiento. Buena práctica: revisar la configuración y rechazar las no esenciales. Las apps "gratuitas" suelen financiarse con los datos de sus usuarios.

✓ Ideas para recordar

- Ley 26.388 = delitos informáticos en el Código Penal.
- Privacidad por diseño = desde el inicio; privacidad por defecto = protegido sin configurar nada.
- Cookies de terceros = de otro dominio; de sesión = se borran al cerrar el navegador.

PARTE IV
Gobierno, factor humano, incidentes y continuidad

Módulo 10 — Hacking ético, OSINT y simulacros de phishing

Definición

El **hacking ético (pentesting)** aplica las mismas técnicas que un atacante, pero **con autorización explícita del dueño del sistema**, para encontrar vulnerabilidades y reportarlas antes que un delincuente.

Tipo	Descripción
White Hat	Hacker ético: con autorización y dentro de la ley.
Black Hat	Ciberdelincuente: sin autorización, viola la ley.
Gray Hat	Zona intermedia: encuentra fallas sin autorización pero las reporta; legalmente ambiguo.

La línea divisoria es el consentimiento

Las técnicas son **las mismas**; lo único que distingue a un white hat de un black hat es la **autorización del dueño**. Escanear sin autorización escrita es acceso indebido.

10.1 Fases del pentesting

1. **Reconocimiento (OSINT):** información pública sin interactuar con el objetivo.
2. **Escaneo y análisis:** puertos, servicios, versiones; se mapea la **superficie de ataque**.
3. **Explotación:** confirmar de forma controlada qué riesgos son reales.
4. **Post-explotación:** medir hasta dónde llegaría un atacante.
5. **Reporte:** hallazgos, evidencias y recomendaciones priorizadas. **Es el verdadero producto** del pentest.

OSINT

Open Source Intelligence: recolección de información de fuentes públicas (LinkedIn, sitio web, WHOIS, ofertas de empleo, redes sociales). Los atacantes la usan para preparar spear phishing e ingeniería social creíbles.

10.2 Señales de alerta de un correo de phishing

Remitente con dominio que no coincide · sentido de urgencia · saludo genérico · enlaces cuya URL real no coincide con el texto · adjuntos inesperados (.zip, .exe, macros) · errores de redacción · pedido de datos sensibles.

10.3 Simulacro de phishing

Prueba controlada en la que la organización envía correos falsos a sus empleados para medir y, sobre todo, **concientizar**.

Métrica	Qué mide	Lo deseable
Tasa de apertura	Cuántos abrieron el correo	Baja
Tasa de clic (CTR)	Cuántos hicieron clic (indicador central)	Baja
Tasa de reporte	Cuántos lo reportaron como sospechoso	**Alta**
Tiempo de reporte	Cuánto tardó el primer aviso a TI	Corto

Para aprender, no para castigar

Sancionar a quien cae genera miedo y hace que nadie reporte incidentes reales. Quien cae recibe capacitación inmediata. La concientización es un **control humano**.

✓ Ideas para recordar

- White Hat vs Black Hat: mismas técnicas, distinta autorización.
- El reporte final es el entregable de mayor valor del pentest.
- En un simulacro se busca CTR baja y tasa de reporte alta.

Módulo 11 — Gobierno de la seguridad y Política de Seguridad Aceptable

Definición

El **gobierno de la seguridad** es el conjunto de políticas, normas, procedimientos, roles y responsabilidades para dirigir, controlar y mejorar la seguridad. La seguridad técnica dice *cómo* se protege; el gobierno dice *quién decide qué se protege, por qué y qué pasa si no se cumple.*

11.1 La pirámide documental

Nivel	Qué es	Ejemplo
Política	Declaración de la dirección: el **qué** y el **por qué**. Estable en el tiempo.	"Todos los datos de clientes se cifran en reposo y en tránsito."
Norma	Regla **obligatoria y específica** que desarrolla la política.	"AES-256 en reposo; TLS 1.2 o superior en tránsito."
Procedimiento	**Pasos operativos detallados** para cumplir la norma.	"Paso 1: generar la clave en el KMS. Paso 2: configurar el bucket…"

Debajo pueden existir guías, instructivos y plantillas (opcionales).

11.2 Política de Seguridad Aceptable (PSA / AUP)

Establece **qué pueden y qué no pueden hacer** empleados y usuarios con los recursos tecnológicos. Importa por lo **legal** (respaldo para sanciones), la **claridad** (elimina zonas grises) y la **cultura**.

Estructura mínima (9 secciones): (1) propósito y alcance; (2) uso aceptable; (3) contraseñas y accesos; (4) correo e internet; (5) dispositivos, BYOD y trabajo remoto; (6) información confidencial; (7) reporte de incidentes; (8) cumplimiento y sanciones; (9) firmas y vigencia.

Regla de oro de una PSA

Corta, clara y específica (2 a 4 páginas), firmada al ingresar y acompañada de capacitación.

11.3 Roles

Rol	Responsabilidad
Dirección / CEO	Aprueba la política, asigna presupuesto. **Responsable último.**
CISO	Lidera la estrategia de seguridad y reporta a la dirección.
DPO	Vela por el cumplimiento de la normativa de datos personales.
Dueño del activo	Responsable de un activo específico.
TI / Seguridad	Implementa controles, monitorea, responde incidentes.
Todos los empleados	Cumplen la PSA, reportan incidentes, cuidan sus credenciales.

En una pyme varios roles pueden recaer en la misma persona, pero **deben existir formalmente**.

✓ Ideas para recordar

- Política (qué y por qué) → Norma (regla específica) → Procedimiento (pasos).
- BYOD = "Bring Your Own Device".
- El responsable último de la seguridad es la Dirección.

Módulo 12 — Factor humano y gestión de incidentes

Las personas son a la vez **el eslabón más débil** (un clic puede comprometer todo) y **la primera línea de defensa** (un empleado capacitado detecta y reporta). Se estima que el 95 % de los incidentes tiene un componente humano. La concientización es un **proceso continuo**: capacitación al ingreso, actualizaciones periódicas, simulacros, micro-learning y métricas.

Definición

Un **incidente de seguridad** es cualquier evento que compromete la confidencialidad, integridad o disponibilidad de los activos. Una **crisis** es un incidente que **escala**: afecta la reputación, exige comunicación externa, involucra reguladores o tiene impacto financiero

significativo.

12.1 Fases de la gestión de incidentes

Fase	Qué se hace	Quién lidera
Detección	Identificar el incidente, su alcance y severidad.	TI / Seguridad
Respuesta	**Contener** el daño, **erradicar** la causa raíz, preservar evidencia.	TI / Seguridad + Legal
Comunicación	Informar a empleados, clientes, reguladores y medios.	Comunicaciones + Legal
Recuperación	Restaurar, monitorear y extraer **lecciones aprendidas**.	Todos los roles

12.2 La Junta de Crisis: 4 roles

Rol	Responsabilidad
Gerencia General	Decisiones estratégicas finales, presupuesto de emergencia, nivel de comunicación pública, pago o no de un rescate.
Legal / Cumplimiento	Cumplimiento normativo (Ley 25.326, GDPR): **si y cuándo notificar a la AAIP**, notificación a titulares, preservación de evidencia.
Comunicaciones	Comunicados internos y externos, prensa y redes sociales.
TI / Seguridad	Contención técnica (aislar o desconectar), forense, restauración.

Simulación "DataShop"

E-commerce de electrónica con 8.000 clientes. Un lunes a las 9:15 TI detecta tráfico de salida inusual desde el servidor de base de datos. Un empleado de Finanzas abrió un adjunto que parecía de un proveedor e instaló software de acceso remoto. Se comprometieron nombres, emails, teléfonos e historial de compras; los datos de pago estaban cifrados, pero no se sabe si la clave fue comprometida. Un foro publica una muestra y el atacante pide rescate.

Inyecciones durante la simulación: consulta de un periodista; un cliente denuncia en redes un email sospechoso; nota de rescate con plazo de 48 h; la AAIP pide información sobre la posible brecha.

✓ Ideas para recordar

- Incidente: lo maneja el equipo operativo. Crisis: el incidente escala.
- Contención = limitar el daño; erradicación = eliminar la causa raíz.
- Legal / Cumplimiento decide sobre notificaciones a la AAIP y la aplicación del GDPR.

Módulo 13 — Continuidad del negocio y auditoría

Definición

BCP (Business Continuity Plan): procesos para que las funciones críticas continúen o se reanuden rápidamente tras una interrupción.
DRP (Disaster Recovery Plan): subconjunto del BCP enfocado en recuperar los **sistemas de información y tecnología**.

	BCP	DRP
Alcance	Todo el negocio: personas, procesos, físico, tecnológico	Solo sistemas de información y tecnología
Pregunta	¿Cómo sigue operando el negocio?	¿Cómo recuperamos los sistemas?
Ejemplo	Mudar la atención al cliente a otra oficina tras un incendio	Restaurar la base desde el backup tras un ransomware

MTD, RTO y RPO (Módulo 6) son la columna vertebral del DRP. Ejemplo: pasarela de pago con MTD 2 h, RTO 1 h, RPO 5 min ⇒ backups cada 5 minutos, replicación en dos regiones y failover automático.

13.1 Componentes de un plan de continuidad

(1) Alcance y objetivos; (2) roles y responsabilidades; (3) criterios de activación; (4) plan de comunicación; (5) procedimientos de recuperación; (6) sitio alternativo; (7) pruebas y simulacros; (8) mantenimiento. **Un plan que nunca se prueba no es un plan**: se prueba al menos una vez al año.

13.2 Auditoría de seguridad

Definición

Examen **sistemático, independiente y documentado** para determinar si las actividades de seguridad cumplen lo planificado y si se implementan eficazmente.

Tipo	Quién la hace y para qué
Interna (primera parte)	La propia organización, para mejorar procesos.
Externa (segunda parte)	Un cliente o partner, para verificar cumplimiento contractual.
De certificación (tercera parte)	Un **organismo independiente**, para certificar un estándar (ej. ISO 27001).

13.3 Ciclo PHVA / PDCA de mejora continua

Planificar (políticas, riesgos, controles) → **Hacer** (implementar) → **Verificar** (auditar, medir: *aquí está la auditoría*) → **Actuar** (corregir y mejorar). La auditoría es una herramienta de mejora, no una "policía".

13.4 Plan de Respuesta a Incidentes: checklist de referencia

Basado en **NIST SP 800-61** (guía de manejo de incidentes) e **ISO/IEC 27001** (gestión de incidentes). Un buen plan incluye: alcance, roles, criterios de activación, fases (detección, contención, erradicación, recuperación), lecciones aprendidas, preservación de evidencia, comunicación interna y externa con plazos legales de notificación, escenarios (ransomware, filtración, caída prolongada), simulacros periódicos, revisión del plan y RTO/RPO de los sistemas críticos.

Uso crítico de la IA

Si un borrador se genera con IA, se audita contra este checklist: se documenta qué omitió, qué era impreciso o genérico, qué no aplica al negocio y qué se adaptó a su tamaño real.

✓ Ideas para recordar

- El BCP incluye al DRP.
- Primera parte = interna; segunda = cliente; tercera = certificación independiente.
- En PHVA, la auditoría corresponde a “Verificar”.

Glosario integrador

Término	Definición
2FA / MFA	Autenticación de dos o múltiples factores.
AAIP	Autoridad de control de datos personales en Argentina.
Access key	Clave de acceso programático a una cuenta cloud.
Activo	Todo lo que tiene valor y debe protegerse.
Amenaza	Evento o actor que *puede* causar daño.
ARCO	Acceso, Rectificación, Cancelación y Oposición.
Auditoría	Examen sistemático e independiente de la seguridad.
BCP / DRP	Plan de continuidad del negocio / de recuperación de sistemas.
BEC	Fraude mediante el correo corporativo comprometido o suplantado.
BIA	Análisis de impacto al negocio.
Bucket	Contenedor de almacenamiento de objetos en la nube.
BYOD	Uso de dispositivos propios en el trabajo.
Certificado digital	Vincula una clave pública con una identidad verificada.
CID	Confidencialidad, Integridad, Disponibilidad.
CISO / DPO	Director de seguridad / Delegado de protección de datos.
Control (prev./det./corr.)	Medida que previene, detecta o corrige incidentes.
Cookie de terceros	Rastreador de un dominio distinto al visitado.
Credential stuffing	Ataque con contraseñas filtradas en otros sitios.
Crisis	Incidente que escala y exige comunicación externa.
CTR	Tasa de clic en un simulacro de phishing.
Dark pattern	Diseño de interfaz engañoso.
Firma digital	Hash cifrado con clave privada: autoría e integridad.
GDPR	Reglamento europeo de protección de datos.
Hash	Función irreversible de salida de longitud fija.
HTTPS / TLS	Protocolo que cifra la comunicación navegador-servidor.
IaaS / PaaS / SaaS	Infraestructura / Plataforma / Software como servicio.
IAM	Gestión de identidades y accesos.
Impacto	Consecuencia del daño materializado.
ISO/IEC 27001 / 27002	Requisitos de un SGSI (certificable) / catálogo de controles.

Término	Definición
Ley 25.326 / Ley 26.388	Datos personales / delitos informáticos (Argentina).
Menor privilegio	Solo los permisos mínimos necesarios.
MTD / RTO / RPO	Tiempo máximo tolerable / objetivo de recuperación / pérdida máxima de datos.
NIST SP 800-61	Guía para el manejo de incidentes de seguridad.
OSINT	Inteligencia de fuentes abiertas.
Pentesting	Prueba de penetración autorizada.
PHVA / PDCA	Planificar, Hacer, Verificar, Actuar.
Privacidad por diseño	Privacidad incorporada desde el inicio del producto.
PSA / AUP	Política de Seguridad Aceptable.
Ransomware	Malware que cifra datos y exige rescate.
Regla 3-2-1	3 copias, 2 medios, 1 fuera del sitio.
Riesgo	Probabilidad $\times$ Impacto.
Salt	Valor aleatorio agregado antes de hashear.
SGSI	Sistema de Gestión de Seguridad de la Información.
Spear phishing	Phishing dirigido y personalizado.
Vulnerabilidad	Debilidad que una amenaza puede explotar.
WAF	Firewall de aplicación web.